PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité des SI et méthodologie EBIOS

09-390 PSE-ER F4-4 Sécurité des SI - méthodologie EBIOS — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La sécurité des SI repose sur la garantie de l'intégrité, de la confidentialité, de la disponibilité, de la non-répudiation/imputation et de l'authentification.
2. La démarche EBIOS est une méthode itérative de gestion des risques qui permet d'aider à une prise de décision éclairée.
3. Le principe de défense en profondeur exige au moins 3 lignes de défense préventive, protectrice et récupératrice.

Synthèse des généralités de la sécurité des SI

Notion	À retenir
Objectifs de sécurité	Garantir **l'intégrité**, la **confidentialité**, la **disponibilité**, la **non-répudiation/imputation** et l'**authentification**.
Évolution des risques	Risques démultipliés par l'**interconnexion** des systèmes et la croissance d'**Internet**, des attaques et des failles.
Politique de sécurité	Stratégie de **compromis** entre fonctionnalités et sécurité, incluant l'identification des risques et la **veille technologique**.
Mise en place	Phases : **mise en œuvre** → **audit** (tests d'intrusion, détection d'incidents) → **tests exploitants** → **réparation**.

Contexte et acteurs de la gestion des risques

Notion	À retenir
Démarche générale	Évaluer les risques et criticité (**cartographie des risques**), sélectionner les parades selon ressources, puis mettre en œuvre et vérifier l'efficacité (tests de fonctionnement, reprise, attaque).
Origines CERT	Novembre **1988** : **ver Internet** sur **Arpanet** (environ **60000** ordinateurs, **3** à **4** % contaminés). La **DARPA** crée le **CERT Coordination Center**.
Acteurs internationaux	**FIRST** (**1990**) : équipes réaction. **CERT** : prévention/assistance. **ISO** (**1947**) : normes.
Acteurs nationaux	**CLUSIF** (**MEHARI**), **ANSSI** (décret **7 juillet 2009**), **Club EBIOS** (**2003**), **CERTA** (**1999**), **CERT** (**CERT-Société Générale**, accrédité **FIRST** en **2010**).

Comparatif des méthodes d'analyse des risques

Notion	À retenir
Méthode OCTAVE	**Université Carnegie Mellon**. Analyse **depuis l'intérieur** (**ressources internes**) sur **actifs** : 3 phases (vue organisationnelle, technique, stratégie de sécurité).
Méthode MEHARI	Développée par le **CLUSIF**. Cadre méthodologique pour identifier les **dysfonctionnements**, évaluer la **gravité**, la **qualité des mesures** et la **probabilité** des situations dangereuses.
Méthode EBIOS	Développée par l'**ANSSI**. Support aux **audits** et **opérations de sécurisation** de l'Agence, largement répandue en France.
Normes ISO 27000	Série de normes internationales (ex: **ISO 27001** cycle **PDCA**, **ISO 27002** remplace **17799** le **01/07/2007**) combinables avec **EBIOS**.

Synthèse de la méthode EBIOS

Notion	À retenir
Finalité et origine	Créée en **1995** par l'**ANSSI**. Permet d'apprécier, traiter et communiquer les risques SI pour aider à une **prise de décision éclairée**.
Les concepts du risque	Risque = **source de menace** + **menace** + **vulnérabilité** + **impact**. Vise à protéger le **patrimoine informationnel**.
Les principes structurants	Établissement du **contexte**, appréciation, traitement (**éviter**, **réduire**, **prendre**, **transférer**, combinables), validation (**homologation**), communication et **surveillance**.
La démarche itérative	Démarche en **5 modules** itératifs. Utilise le formalisme **RACI** et l'exemple de la société **@RCHIMED**.

Résumé de l'étude du contexte

Notion	À retenir
Définir le cadre	**5 actions** : cadrer l'étude, décrire contexte, délimiter périmètre, identifier paramètres et sources de menaces.
Préparer les métriques	Fixe paramètres et échelles pour garantir l'**homogénéité** et la **répétabilité**. Inclut critères de sécurité, échelles de **gravité**, de **vraisemblance** et critères de gestion.
Identifier les biens	**Biens essentiels** (informations, processus : on apprécie leurs **besoins** de sécurité) et **biens supports** (composants techniques ou non sur lesquels ils reposent, porteurs des **vulnérabilités**).

Modules 2 à 4

Module	À retenir
2. Événements redoutés	scénarios génériques à éviter, niveau **fonctionnel**, sur les **biens essentiels**
3. Scénarios de menaces	modes opératoires, niveau **technique**, sur les **biens supports** (menaces + vulnérabilités + sources) ; analyser (systémique) puis évaluer (trié par vraisemblance)
4. Risques	risque = événement redouté + scénarios liés (mêmes biens, même critère, mêmes sources) ; estimation **brute** puis **nette** ; objectifs de sécurité ; risques **résiduels**

Synthèse du Module 5

Notion	À retenir
Formaliser les mesures	Déterminer les mesures (référentiels, créées), analyser les risques résiduels et établir une **déclaration d'applicabilité**.
Défense en profondeur	Appliquer la **complétude** : au moins **3 lignes de défense** pour les biens essentiels, avec globalité, coordination, dynamisme, suffisance et démonstration.
Mettre en œuvre/Homologuer	Élaborer le **plan d'action**, ré-analyser les risques résiduels et prononcer l'**homologation de sécurité** (provisoire, complète ou refus).

Pièges et confusions

- ⚠ Confondre le bien essentiel (dont on apprécie les besoins de sécurité) et le bien support (sur lequel reposent les vulnérabilités).
- ⚠ Confondre l'événement redouté (niveau fonctionnel sur les biens essentiels) et le scénario de menace (niveau technique sur les biens supports).
- ⚠ Croire que la démarche EBIOS est linéaire alors qu'elle est itérative.
- ⚠ Omettre de vérifier l'efficacité réelle des protections par des tests en mode dégradé ou d'attaque malveillante.
- ⚠ Confondre les acteurs : le FIRST fédère les équipes, tandis que l'ANSSI édite la méthode EBIOS.
- ⚠ Confondre l'estimation brute (sans mesures de sécurité) et l'estimation nette (avec mesures de sécurité).

Sigles et définitions

Système d'information	Ensemble organisé des ressources humaines, matérielles, logicielles et procédurales d'une organisation.
Parade	Solution de sécurité retenue pour traiter un risque avec des ressources limitées.
CERT	Organisme officiel de prévention des risques et d'assistance au traitement des incidents.
Bien essentiel	Information ou processus important dont on apprécie les besoins de sécurité mais pas les vulnérabilités.
Bien support	Composant technique ou non technique sur lequel repose un bien essentiel et qui porte des vulnérabilités.
Risque	Combinaison d'un événement redouté et de tous les scénarios de menaces concernés.

Auto-test

1. Quelle est la différence entre le système d'information et le système informatique ?
2. Quelles sont les quatre options de traitement du risque ?
3. Quelle méthode d'analyse des risques est développée par le CLUSIF ?
4. Quelle est la date de création de l'ANSSI ?
5. Que signifie l'acronyme EBIOS ?

Réponses : **1.** Le SI organise les activités et le système informatique est le moyen technique au cœur du SI. · **2.** Éviter, réduire, prendre et transférer. · **3.** La méthode MEHARI. · **4.** Par le décret numéro 2009-834 du 7 juillet 2009. · **5.** Expression des Besoins et Identification des Objectifs de Sécurité.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.